Private Exposure Registry: ארכיטקטורה · Case 02

פרק 3 (ארכיטקטורה) בתבנית תיק הפרויקט של מגשימים: מבט על, התאמה לאפיון, ועיצוב נתונים וישויות מידע. נוספו שלושה סעיפים שאינם בתבנית ומשמשים את שלב ההשוואה: דפוסים ארכיטקטוניים ופשרות, תרחישי כשל וסדר בנייה, ובדיקת סגירה.

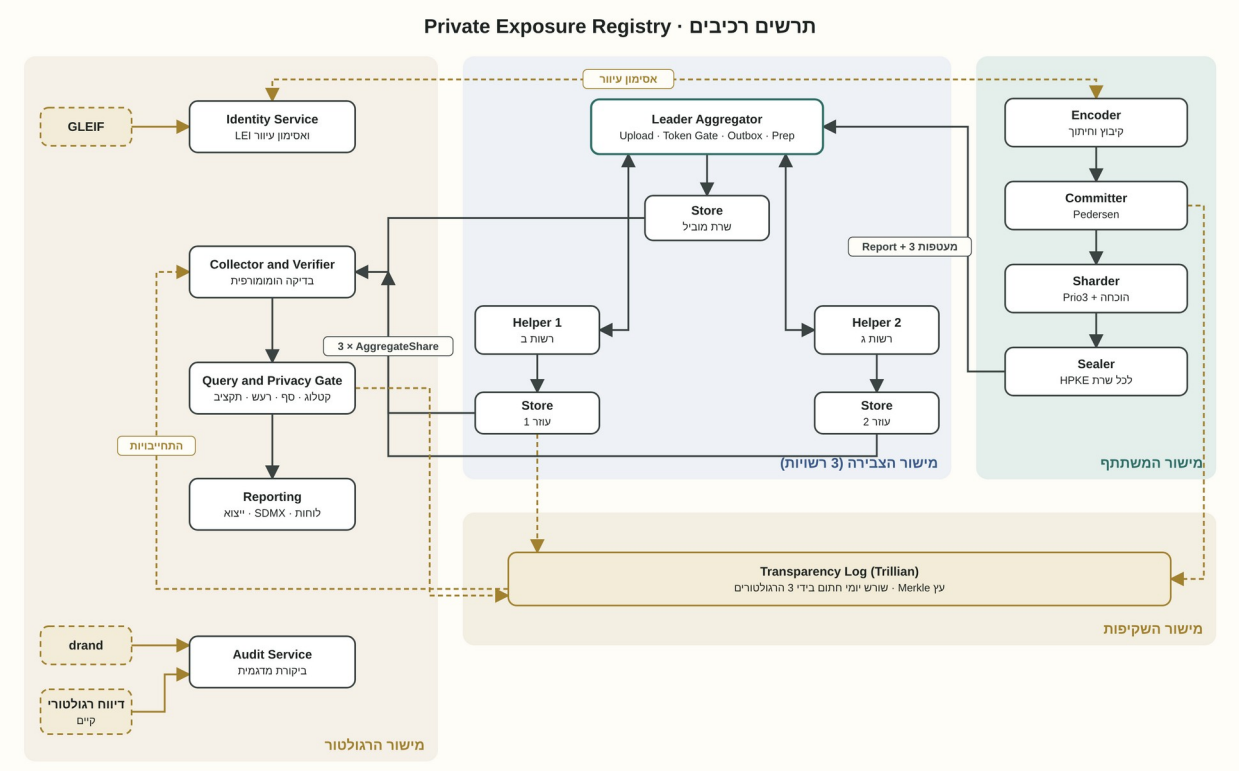
מבט על

העיקרון שמארגן את כל המבנה

במערכת הזו אף אחד לא סומך על אף אחד, והמבנה משקף את זה. יש ארבעה מישורים (planes), וכל רכיב שייך לאחד מהם בלבד. מידע עובר בין מישורים רק בצורה שבה המישור המקבל לא יכול לנצל אותו:

- **מישור המשתתף:** האפליקציה שרצה אצל הגוף המדווח. הנתונים הגולמיים לא יוצאים ממנו, רק מעטפות מוצפנות והתחייבויות.
- **מישור הצבירה:** שלושה שרתים, כל אחד אצל רשות פיקוח אחרת. כל אחד רואה רק את החלק שלו, שנראה כמו רעש.
- **מישור הרגולטור:** זהות, אימות התוצאה, קטלוג השאלות, ופרסום. רואה סכומים, אף פעם לא דיווח בודד.
- **מישור השקיפות:** יומן ציבורי שכל אחד יכול לקרוא, ואף אחד לא יכול לשנות.

תרשים רכיבים



הרכיבים

- **Participant Client (מישור המשתתף):** אפליקציה ב-Rust, גם שולחנית וגם WebAssembly בדפדפן. ארבעה תתי-רכיבים לפי סדר הפעולה: Encoder (ממיר את ספר ההלוואות לווקטור מקובץ וחתוך), Committer (מחשב התחייבויות Pedersen), Sharder (Prio3: פיצול והוכחת תקינות), ו-Sealer (HPKE: מעטפה מוצפנת לכל שרת).

- **Identity Service (מישור הרגולטור):** מאמת LEI מול מאגר GLEIF ומול רשימת הגופים המפוקחים, ומנפיק אסימון השתתפות עיוור אחד לגוף לתקופה. מפתח החתימה ב-HSM.
- **Leader Aggregator (מישור הצבירה):** נקודת הכניסה של הדיווחים. ארבעה תתי-רכיבים: Upload API (מקבל דיווחים ומחזיר קבלה), Token Gate (בודק חתימה ושימוש חוזר באסימון), Forward Outbox (מעביר לעוזרים את המעטפות שלהם, עם התמדה), ו-Prep Coordinator (מנהל את שלב האימות המשותף).
- **Helper Aggregator 1 ו-2 (מישור הצבירה):** כל אחד פותח את המעטפה שלו, משתתף באימות, וצובר. ההבדל היחיד בינם לבין המוביל: הם לא מקבלים דיווחים ישירות ממשתתפים.
- **Aggregate Store (אחד בכל שרת):** PostgreSQL שמחזיק את החלקים והסכומים החלקיים של אותו שרת בלבד.
- **Collector and Verifier (מישור הרגולטור):** מקבל את שלושת הסכומים החלקיים, מחבר אותם, ובודק אותם מול סכום ההתחייבויות. אם הבדיקה נכשלת, מנהל את החיפוש הבינארי.
- **Query and Privacy Gate (מישור הרגולטור):** קטלוג השאלות, שער הסף K=5, רעש Discrete Gaussian לפרסום הציבורי, וספר תקציב הפרטיות.
- **Reporting (מישור הרגולטור):** לוחות לרגולטורים, הפרסום הציבורי ב-SDMX, וייצוא ההתפלגויות.
- **Audit Service (מישור הרגולטור):** בחירת משתתפים לביקורת מדגמית לפי ערך drand, והשוואה של ההתחייבויות שנפתחו לדיווח הרגולטורי הקיים.
- **Transparency Log (מישור השקיפות):** Trillian, יומן מבוסס עץ Merkle. כל הרכיבים כותבים אליו, וכולם יכולים לקרוא ממנו.
- **רכיבים חיצוניים:** מאגר GLEIF (זיהוי), רשת drand (אקראיות ציבורית), והדיווח הרגולטורי הקיים (Form PF, AIFMD Annex IV) שהרגולטור כבר מחזיק.

טבלת רכיבים: תפקיד וממשקים

רכיב	תפקיד	ממשקים נכנסים	ממשקים יוצאים
Participant Client	קידוד, התחייבות, פיצול, הצפנה	ספר הלוואות מקומי, תבנית, מפתחות HPKE, אסימון	Report ו-CommitmentSet ל-Leader
Identity Service	אימות LEI והנפקת אסימונים עיוורים	בקשת הצטרפות, אסימון מוסתר	חתימה עיוורת על אסימון
Leader Aggregator	קליטה, בדיקת אסימון, העברה, תיאום אימות	דיווחים ממשתתפים	מעטפות לעוזרים, קבלות, AggregateShare
Helper Aggregator 1, 2	פתיחת מעטפה, אימות, צבירה	מעטפות והודעות אימות מה-Leader	הודעות אימות, AggregateShare
Aggregate Store	שמירת חלקים וסכומים חלקיים של שרת אחד	כתיבה מהשרת שלו בלבד	קריאה מהשרת שלו בלבד
Collector and Verifier	חיבור הסכומים ובדיקה הומומורפית	שלושה AggregateShare, התחייבויות מהיומן	סכום מאומת או זיהוי כשל
Query and Privacy Gate	קטלוג, סף, רעש, תקציב	סכום מאומת, ספירות, בקשת שאלה	תשובה מדויקת לרגולטור, תשובה עם רעש לציבור
Reporting	לוחות, פרסום, ייצוא	תשובות מה-Gate	לוחות, SDMX, Parquet
Audit Service	ביקורת מדגמית	ערך drand, יומן, דיווח רגולטורי קיים	תוצאות ביקורת ליומן
Transparency Log	יומן בלתי משתנה	אירועים מכל הרכיבים	שורש חתום, הוכחות הכללה ועקביות

התאמה לאפיון

פיצ'ר מהאפיון	רכיבים מעורבים	סדר פעולות ולמה
1. רישום וזהות	Participant Client ← Identity Service ← GLEIF	הלקוח מסתיר את האסימון לפני שהוא נשלח לחתימה, כך שהרגולטור חותם בלי לראות אותו, ולא יוכל לקשר אותו לדיווח
2. קידוד מקומי	Participant Client (Encoder)	קורה לפני כל דבר אחר, ובמחשב של המשתתף בלבד
3. התחייבויות וקבלות	Participant Client (Committer) ← Leader (Upload API) ← Transparency Log	ההתחייבות נוצרת לפני הפיצול, כדי שיהיה אפשר להוכיח מה נשלח עוד לפני שהשרתים נגעו בו
4. פיצול והוכחה	Participant Client (Sharder, Sealer)	ההוכחה מפוצלת יחד עם הנתונים, כך ששום שרת לא מחזיק הוכחה שלמה
5. צבירה	Leader ← Helpers ← Aggregate Store בכל שרת	בדיקת אסימון לפני כל דבר, אימות משותף לפני צבירה, וצבירה רק של דיווחים שעברו
6. אימות נכונות	Aggregate Stores ← Collector and Verifier ← Transparency Log	הבדיקה ההומומורפית רצה לפני שהסכום מגיע לקטלוג. סכום שלא עבר בדיקה לא נפתח לשום שאלה
7. קטלוג ופרטיות	Collector and Verifier ← Query and Privacy Gate	הסף נבדק לפני הרעש, והתקציב נבדק לפני הפרסום. שאלה שתחרוג מהתקציב נדחית לפני שחושבה
8. תקשורת ותפעול	Sealer, Forward Outbox, mTLS בין השרתים	המעטפה של עוזר נשמרת אצל המוביל עד שהוא חוזר. המוביל לא יכול לפתוח אותה
9. יומן וביקורת	כל הרכיבים ← Transparency Log; Audit Service ← drand	כל רכיב כותב ליומן לפני שהוא מאשר פעולה, כך שאין פעולה בלי רשומה
10. דוחות ופרסום	Query and Privacy Gate ← Reporting	הלוח לרגולטור מציג מדויק, והפרסום הציבורי עם רעש ומרווח טעות. שניהם מפנים לרשומת האימות ביומן

עיצוב נתונים וישויות מידע

מידע שעובר בין רכיבים (לא נשמר בצורה הזו)

- **BlindedToken ו-BlindSignature, בין Participant Client ל-Identity Service:** אסימון מוסתר וחתימה עליו. לאחר ההסרה, הלקוח מחזיק אסימון שהרגולטור מעולם לא ראה.
- **Report, מ-Participant Client ל-Leader:** מזהה דיווח, task_id, חלק ציבורי, שלוש מעטפות HPKE (אחת לכל שרת), ואסימון.
- **CommitmentSet, מ-Participant Client ל-Leader ומשם ליומן:** התחייבות לכל תא.
- **PrepMessage, בין השרתים דרך ה-Leader:** הודעות האימות של Prio3. קצרות, ולא חושפות ערכים.
- **AggregateShare, מכל שרת ל-Collector:** סכום חלקי, סכום חלקי של ערכי r, מספר דיווחים, וטביעת אצבע של רשימת הדיווחים.
- **QueryRequest ו-QueryResponse, בין Reporting ל-Gate:** מזהה שאלה מהקטלוג, ותשובה עם סימון תאים חסומים.

מידע שנשמר

- **בכל Aggregate Store:** tasks, reports (המעטפה של אותו שרת בלבד, עד סוף תקופת השימור), aggregate_shares, ואצל המוביל גם used_tokens ו-pending_forwards.
- **אצל הרגולטור:** participants, token_issuance, templates, catalog_versions, batches, budget_ledger, releases, audit_selections.
- **ביומן השקיפות:** כל אירוע כעלה בעץ, ושורש יומי חתום על ידי שלושת הרגולטורים.
- **אצל המשתתף:** ערכי r ותוצאות החיתוך, מקומית, לצורך ביקורת עתידית. אף פעם לא בשרתים.

הפרדה מכוונת

אין מקום אחד במערכת שבו נמצאים יחד גם זהות של משתתף וגם תוכן הדיווח שלו. הזהות (LEI) נמצאת רק ב-Identity Service. התוכן נמצא רק מפוצל בין שלושה שרתים. האסימון העיוור הוא הגשר, והוא בנוי כך שאי אפשר לחצות אותו בכיוון ההפוך.

דפוסים ארכיטקטוניים ופשרות

היומן כמקור האמת (Event Sourcing)

ברוב המערכות, מסד הנתונים הוא האמת והיומן הוא תיעוד. כאן ההפך: יומן השקיפות הוא מקור האמת, והמצב אצל הרגולטור (אילו אצוות אומתו, כמה תקציב נוצל) הוא "תצוגה" שנבנית מקריאת היומן. כל רכיב כותב אירוע ליומן לפני שהוא מאשר פעולה.

- **מה מרוויחים:** אפשר לבנות מחדש את כל מצב הרגולטור מהיומן בלבד. כל טענה כמו "נוצלו 0.6 מהתקציב" ניתנת לבדיקה בידי כל אחד. ואי אפשר לשנות היסטוריה בשקט.
- **מה משלמים:** כתיבה ליומן היא חלק מכל פעולה, ולכן היומן חייב להיות זמין. ושינוי במבנה של אירוע אחרי שנכתב הוא מסובך, כי ישנים לא נמחקים.

הפרדת כתיבה וקריאה (CQRS)

מסלול הכתיבה (קליטת דיווחים, אימות, צבירה) ומסלול הקריאה (שאלות, לוחות, פרסום) הם שני מודלים נפרדים לגמרי. מסלול הכתיבה עובד על חלקים מוצפנים בשלושה שרתים. מסלול הקריאה עובד רק על סכומים מאומתים אצל הרגולטור.

- **מה מרוויחים:** אין שום נתיב שבו שאלה של רגולטור נוגעת בדיווח בודד. ההפרדה היא לא רק ארגון קוד, היא חלק מהאבטחה.
- **מה משלמים:** תשובה זמינה רק אחרי שאצווה נסגרה ואומתה. אין "שאלה חיה" על דיווחים שעוד בתהליך.

תיבת דואר יוצא (Transactional Outbox)

כשהמוביל מקבל דיווח, הוא שומר את הדיווח ואת "הודעות ההעברה" לשני העוזרים באותה טרנזקציה במסד הנתונים. תהליך נפרד שולח את ההודעות, ומוחק אותן רק אחרי אישור קבלה.

- **מה מרוויחים:** אין מצב שבו דיווח התקבל אבל העוזר לא קיבל את החלק שלו. זה מה שמאפשר את ההחלטה "כל שלושת השרתים נחוצים" בלי לאבד דיווחים כשעוזר לא זמין.
- **מה משלמים:** העברה לעוזר היא "בסופו של דבר", לא מיידית. ייתכנו כפילויות, ולכן העוזר חייב לזהות דיווח שכבר קיבל לפי report_id.

כלל שלושת המפתחות (Multi-Party Governance)

שינוי בקטלוג השאלות, בתבנית הדיווח או בתקציב דורש אישור של שלושת הרגולטורים, שכל אחד חותם עליו במפתח שלו, והשינוי נרשם ביומן. דומה לכלל "שני אנשים" בכספות ובמערכות נשק, אבל בשלושה.

- **מה מרוויחים:** אף רשות לבדה לא יכולה להוסיף שאלה שנועדה לחשוף משתתף, או להגדיל את התקציב בשקט.
- **מה משלמים:** שינויים איטיים. אם רשות אחת לא מגיבה, אין שינוי. זה מכוון.

בנייה על סטנדרט במקום המצאה

ליבת המערכת (פיצול, הוכחה, צבירה) היא Prio3 ו-DAP לפי טיוטות IETF, עם המימושים libprio-rs ו-Janus. הקוד שלנו מוסיף את מה שהסטנדרט לא נותן: שלושה שרתים, התחייבויות ואימות הומומורפי, אסימונים עיוורים, קטלוג ותקציב.

- **מה מרוויחים:** קריפטוגרפיה שנבדקה על ידי אחרים ורצה בייצור.
- **מה משלמים:** הטיוטות עדיין משתנות. הרחבה לשלושה שרתים היא מעבר למה ש-DAP מגדיר היום, ולכן היא הקוד הרגיש ביותר שלנו.

תרחישי כשל

מה נכשל	מה קורה	למה זה בסדר (או לא)
עוזר אחד לא זמין	דיווחים ממשיכים להתקבל. המעטפות שלו מחכות ב-Outbox. האצווה לא נסגרת עד שהוא חוזר	הפשרה שבחרנו: עיכוב בדוח, לא דליפה ולא אובדן
המוביל לא זמין	משתתפים לא יכולים לדווח. האפליקציה שומרת את הדיווח מוצפן ומנסה שוב	הנתונים לא אובדים, והמשתתף מקבל קבלה כשההגשה מצליחה
בדיקת התחייבויות נכשלת	הסכום לא נפתח. חיפוש בינארי מוצא את הדיווח או את השרת הבעייתי	עדיף אין תשובה מתשובה שגויה
שרת שולח חלק משובש	הבדיקה ההומומורפית נכשלת, והחיפוש הבינארי מצביע על השרת	השרת מזוהה, ויש הוכחה ביומן
דיווח לא עובר את הוכחת התקינות	הדיווח נזרק, והקבלה מראה שנזרק ולמה	משתתף יכול לבדוק את עצמו ולתקן
תקציב הפרטיות נגמר	אין עוד פרסומים לציבור לתקופה. הרגולטורים עדיין רואים מדויק	לא מוכרים פרטיות בשביל עוד גרף
היומן לא זמין	כל פעולה שדורשת רשומה נעצרת	אין פעולה בלי עדות. זה מכוון, וזו הסיבה שהיומן משוכפל

סדר בנייה

- **ספרינט 1, הליבה עם שני שרתים:** Participant Client (Encoder, Sharder) ו-Leader ו-Helper אחד, על libprio-rs ו-Janus כמו שהם. מטרה: דיווח, אימות וצבירה מקצה לקצה לפי הסטנדרט.
- **ספרינט 2, שלושה שרתים:** הרחבה לעוזר שני, Forward Outbox, ו-HPKE לכל שרת.
- **ספרינט 3, התחייבויות ואימות:** Committer, Collector and Verifier, בדיקה הומומורפית וחיפוש בינארי.
- **ספרינט 4, זהות:** Identity Service, אסימונים עיוורים, Token Gate, וחיבור ל-GLEIF.
- **ספרינט 5, שקיפות:** Transparency Log (Trillian), כתיבה מכל הרכיבים, שורש חתום.
- **ספרינט 6, קטלוג ופרטיות:** Query and Privacy Gate, בדיקת ההפרשים, OpenDP ותקציב.
- **ספרינט 7, דוחות וביקורת:** Reporting, פרסום SDMX, Audit Service עם drand.

בדיקת סגירה

השאלה של בדיקת הסגירה פשוטה: האם המערכת יכולה לקיים את ההבטחה המרכזית שלה מקצה לקצה, רק עם רכיבים שנמצאים בתוך הגבולות שלה? ההבטחה המרכזית של הפרויקט, מהייזום: לראות משבר שמגיע לאט, לפני שהוא מגיע מהר. כלומר, לומר משהו על השוק כפי שהוא היום.

רכיב או קלט	בתוך הגבולות?	האם ההבטחה תלויה בו?
נתוני החשיפה והמנוף של השוק	כן: נאספים מהמשתתפים עצמם, דרך המערכת	כן, וזה הקלט המכריע
קידוד, פיצול, צבירה ואימות	כן	כן, ונמצא בשליטה מלאה
קטלוג, סף ופרטיות	כן	כן, ונמצא בשליטה מלאה
מאגר GLEIF	לא	לא: רק לזיהוי. ניתן להחלפה ברשימת הגופים שהרגולטור כבר מחזיק
רשת drand	לא	לא: רק לבחירת ביקורת. ניתן להחלפה בכל מקור אקראיות ציבורי
הדיווח הרגולטורי הקיים	לא, אבל כבר אצל הרגולטור	רק לביקורת המדגמית, לא לתוצאה

הקלט המכריע, מה כל גוף מחזיק ובאיזה מנוף, נכנס למערכת דרך הרכיבים שלה, עובר בה, ויוצא ממנה כתמונה מאומתת. שלושת התלויות החיצוניות משמשות לזיהוי ולביקורת, לא לתשובה, וכל אחת מהן ניתנת להחלפה.

מה המערכת לא מבטיחה, וזה כתוב גם באפיון: היא מראה את התמונה, לא מה יקרה לה. היא יודעת לומר "הרבה מהחשיפה נמצאת בריבית מעל 5%, ושליש מהקרנות ממונפות מעל פי 4". היא לא יודעת לומר "ואם הריבית תעלה עוד נקודה, זה מה שיקרה". אבל מה שהיא כן מבטיחה, היא מבטיחה מקצה לקצה, בתוך הגבולות שלה.